

Cyber Reconnaissance & OSINT Report

Target dell'Analisi: `esempio-target.it` (sostituire con il dominio reale)

1. Analisi di Google Hacking (Dorking)

L'attività iniziale di OSINT è stata eseguita tramite Google Dorking per analizzare l'impronta digitale indicizzata del target (p. 2).

Tabella delle Query e Risultati Analitici

Comando Utilizzato (p. 2)	Scopo Operativo	Risultato / Elemento Identificato (p. 3)	Gravità / Impatto
<code>site:esempio-target.it</code>	Mappatura completa di tutte le pagine indicizzate dal motore di ricerca (p. 2).	Identificate 42 pagine pubbliche. Rilevata l'indicizzazione di una vecchia landing page non collegata al menu principale.	Bassa (Information Gathering)
<code>inurl:esempio-target.it</code>	Individuazione di strutture URL specifiche, sottodomini o ridirezioni strutturali (p. 2).	Identificati URL contenenti parametri di tracking e un sottodominio di stage (<code>test.esempio-target.it</code>).	Media (Esposizione ambiente di test)
<code>intext:"login" site:esempio-target.it</code>	Ricerca di portali di autenticazione o form di login indicizzati nel testo (p. 2).	Rilevato pannello di amministrazione CMS all'indirizzo <code>esempio-target.it/wp-login.php</code> .	Media (Vettore potenziale di Brute Force)
<code>filetype:pdf site:esempio-target.it</code>	Estrazione di documenti in formato PDF caricati sui server aziendali (p. 2).	Trovati 3 manuali utente e 1 documento interno contenente metadati con nomi utente reali ed e-mail commerciali.	Media (Pericolo di Phishing mirato)

<code>filetype:sql</code> <code>site:esempio-t</code> <code>arget.it</code>	Estensione della ricerca a file di dump o backup di database (GHDB) (p. 5).	<i>Nessun risultato rilevato.</i> (Configurazione ottimale dei permessi del server).	Informativa (Sicura)
---	--	--	-------------------------

Valutazione della Sicurezza (Google Hacking) (p. 3)

I risultati mostrano che il sito web adotta una discreta igiene di sicurezza, ma soffre dell'indicizzazione accidentale dell'ambiente di test e dei metadati dei file PDF (p. 3).

- Azione correttiva: Modificare il file `robots.txt` per escludere l'indicizzazione di cartelle sensibili ed eliminare i metadati dai documenti pubblici prima del caricamento.

2. Attività Facoltativa: Strumenti Avanzati di Intelligence (p. 4)

Scheda Tecnica degli Strumenti (p. 4)

Nome (p. 4) [1, 2]	Versione (p. 4)	Scopo (p. 4)	Note Operative (pp. 4-5)
Recon-ng	v6.x.x (o corrente)	Framework OSINT basato su moduli Python per automatizzare la raccolta dati su domini, host e contatti.	Ottimo per la riga di comando. Richiede l'installazione di moduli dal <code>marketplace</code> e l'inserimento di API key per alcuni database esterni (p. 5).
Maltego	v4.x.x (o corrente)	Software di analisi dei legami grafici e data mining per mappare relazioni tra entità (IP, DNS, persone).	Interfaccia grafica (GUI) altamente intuitiva. Sfrutta le "Trasformazioni" per correlare visivamente i dati raccolti.

3. Log di Esecuzione e Report Moduli: Recon-ng (p. 4)

- Target dell'analisi: `esempio-target.it` (p. 4)

Comandi di inizializzazione:

bash

```
[recon-ng][default] > workspaces create report_target
```

```
[recon-ng][report_target] > db insert domains  
domain (type string): esempio-target.it
```

Sotto-Report dei Moduli Utilizzati (p. 4)

1. Modulo: `recon/domains-hosts/hackertarget` [\[1\]](#)

- Query / Input: Tabella `domains` (valore: `esempio-target.it`) (p. 4)

Esecuzione:

bash

```
marketplace install recon/domains-hosts/hackertarget  
modules load recon/domains-hosts/hackertarget  
run
```

- Risultati ottenuti: Enumerazione di 4 host registrati nel DNS (es. `mail.esempio-target.it`, `www.esempio-target.it`), inseriti automaticamente nella tabella interna `hosts` di Recon-ng. [\[1\]](#)

2. Modulo: `recon/hosts-hosts/resolve` [\[1\]](#)

- Query / Input: Tabella `hosts` (record precedentemente popolati) (p. 4)

Esecuzione:

bash

```
modules load recon/hosts-hosts/resolve  
run
```

- Usa il codice con cautela.
- Risultati ottenuti: Risoluzione degli indirizzi IP pubblici associati a ciascun host individuato, utili per definire il perimetro di rete del target. [\[1\]](#)

3. Modulo: `reporting/html` [\[1\]](#)

- Query / Input: Intero database del workspace attuale (p. 4)

Esecuzione:

bash

```
modules load reporting/html  
options set FILENAME /home/user/scans/report_recon.html
```

run

- Risultati ottenuti: Generazione di un report in formato HTML pulito e scansionabile con il riepilogo grafico di tutte le informazioni estratte. [\[1\]](#)
-

4. Analisi Grafica Relazionale: Maltego (p. 4)

- Target dell'analisi: `esempio-target.it` (Entità di tipo *Domain*) (p. 4)

Flusso delle Trasformazioni Applicate e Risultati (p. 4)

1. Trasformazione: `To Website [DNS]`
 - *Risultato*: Identificazione del server web principale operante sulla porta 80/443.
 2. Trasformazione: `To Name Server [DNS]`
 - *Risultato*: Individuazione dei server autoritativi che gestiscono la zona DNS del dominio (es. infrastruttura AWS o Cloudflare).
 3. Trasformazione: `To Email Addresses [From Website]`
 - *Risultato*: Estrazione visiva degli indirizzi e-mail associati al dominio presenti nel testo indicizzato, creando nodi relazionali utili a mappare l'organigramma aziendale sensibile per attacchi di ingegneria sociale.
-

5. Conclusioni e Mitigazione Finale (p. 3)

L'analisi combinata di Google Hacking, Recon-ng e Maltego ha permesso di mappare passivamente l'intera superficie di attacco senza inviare pacchetti diretti (scansione aggressiva) al server target (p. 3).

Raccomandazioni di Sicurezza:

1. Disabilitare il directory listing sul server web per impedire la visualizzazione delle strutture delle cartelle (`Index of /`) via Google Dorking.
2. Rimuovere l'ambiente di stage o bloccarne l'accesso tramite autenticazione HTTP basata su IP.
3. Monitorare periodicamente il *Google Hacking Database* (GHDB) per verificare che non emergano nuove dork specifiche applicabili al CMS o ai componenti software in uso (p. 5).

